

Vulnerability Scanning & Enumeration

Module 2 — Reconnaissance · Unit 09

You found the open doors in Unit 08. Now you learn *exactly* what's behind each one — and which are weak. Then you STOP at the plan.

Where we are in Module 2

- Unit 07 — Passive recon (OSINT): read public records.
- Unit 08 — Active recon & scanning: found live hosts, open ports, versions.
- **Unit 09 — Vuln scanning & enumeration** ← this week, the final unit of the module.

This week: turn open ports into detailed findings and a prioritized **attack plan** — then write the **Recon mini-project**.

Learning objectives (1 of 2)

By the end of this unit you can:

- **Distinguish** scanning, enumeration, and vulnerability scanning.
- **Manually enumerate** HTTP, FTP, SMB, and SSH — and explain why manual still matters.
- **Run** targeted nmap **NSE scripts** and interpret the output.
- **Describe** automated vuln scanners (Nessus, OpenVAS) at an awareness level.

Learning objectives (2 of 2)

- **Map** a service/version to a **CVE** and read its **CVSS** severity.
- **Spot** likely **false positives** and verify them manually.
- **Turn** findings into a prioritized **attack plan** — without exploiting.
- **Produce** the Module 2 **Recon mini-project report**.

Vocabulary — the three steps

Term	Meaning
Scanning	Finding live hosts and open ports (Unit 08) — "what's there."
Enumeration	Digging into a service for users, shares, versions, config — "what exactly is it."
Vulnerability scanning	Checking services/versions against known weaknesses — "what's weak."
Vulnerability	A weakness that could be exploited to harm CIA (confidentiality, integrity, availability).

Vocabulary — tools & services

Term	Meaning
Service enumeration	Probing a specific service (HTTP/FTP/SMB/SSH) for usable detail.
SMB	Server Message Block — Windows file/printer sharing; often enumerable.
NSE	Nmap Scripting Engine — small scripts that automate enumeration/detection/vuln checks.
Automated vuln scanner	A tool (Nessus, OpenVAS) that scans broadly and flags possible vulnerabilities.
Nessus Essentials	A free-for-limited-use vuln scanner (IP-capped).
OpenVAS / Greenbone	A free, open-source vuln scanner.

Vocabulary — findings

Term	Meaning
CVE	Common Vulnerabilities and Exposures — a public ID for one known flaw (e.g., CVE-2011-2523).
CVSS	A 0–10 severity score (higher = more severe).
False positive	A finding a tool reports that turns out not to be real/exploitable.
Attack surface	All the points where a target could be probed or attacked.
Attack plan	A prioritized list of what an attacker would try, and why.

Day 1

Scanning vs enumeration vs vuln scanning; why manual matters

Warm-up

Last unit you found open **port 445 running Samba**. What's the **next** question you'd ask about it?

- What **shares** are exposed?
- What **users** exist?
- What **version** is it, and is that version weak?

That digging is **enumeration**.

Three steps that build on each other

Step	Question it answers
Scanning (Unit 08)	"What's there?" — live hosts, open ports
Enumeration	"What <i>exactly</i> is it?" — users, shares, versions, config
Vuln scanning	"Which of these is <i>weak</i> ?" — match versions to known flaws

Each step uses the output of the last. You can't enumerate a service you haven't found, and you can't map a vuln without the version.

Why manual enumeration still matters

- Automated tools **miss context** and produce **false positives**.
- A human can spot a **misconfiguration** a scanner ignores.
- Manual enumeration finds **users and shares** a port scan never reveals.

Tools are fast; judgment is irreplaceable. Use both.

Lab Setup + Part A — HTTP enumeration

```
curl -I http://<target-ip>/          # server header
curl http://<target-ip>/robots.txt    # disallowed paths (if present)
```

- Read the **server header** (e.g., Apache 2.2.8).
- Check **robots.txt** for paths someone tried to hide.
- Browse the site for apps, login pages, directory listings.

Web apps (DVWA, Mutillidae, phpinfo) = a rich attack surface for Module 3.

Exit ticket — Day 1

In one sentence each, define **scanning**, **enumeration**, and **vuln scanning**.

Day 2

Manual enumeration of common services (HTTP, FTP, SMB, SSH)

Warm-up

What could an **anonymous FTP login** or an **open SMB share** leak?

- Anonymous FTP → files the owner forgot were public.
- Open SMB share → documents, backups, even credentials.
- Both can hand you **usernames** for later attacks.

FTP enumeration (port 21)

```
ftp <target-ip>      # user: anonymous  password: (anything)
```

- Try an **anonymous login** — does it work?
- If it does, **list and browse** the files visible.
- Note the **banner/version** (e.g., `vsFTPd 2.3.4`).

Anonymous access = an open door. What's inside is the finding.

SMB enumeration (ports 139/445)

```
smbclient -L //<target-ip>/ -N      # list shares (no password)
enum4linux -a <target-ip>          # shares + users + more
```

- **Shares:** e.g., `tmp`, `IPC$`.
- **User accounts:** e.g., `msfadmin`.

This is the classic lesson: manual SMB enumeration finds **users and shares** a **port scan never could**.

SSH enumeration (port 22)

```
nc <target-ip> 22      # read the banner
```

- Read the **banner/version** (e.g., `SSH-2.0-OpenSSH_4.7p1`).
- Note supported **auth methods** if shown.

Even a "locked" service like SSH announces its version — a CVE lead.

Lab Part B — FTP, SMB, SSH

```
ftp <target-ip>  
smbclient -L //<target-ip>/ -N  
enum4linux -a <target-ip>  
nc <target-ip> 22
```

Record: whether anonymous FTP worked and what was visible; SMB shares/users found; SSH version. Note which findings a **plain port scan would have missed**.

Exit ticket — Day 2

Name **one thing manual SMB enumeration can find** that a quick port scan won't.

Day 3

nmap NSE scripts + automated vuln scanners
(awareness)

Warm-up

What if nmap could run a **small program** against each open port to dig deeper?

It can. They're called **NSE scripts** — the Nmap Scripting Engine.

nmap NSE scripts

```
nmap --script ftp-anon -p 21 <target-ip>  
nmap --script smb-os-discovery,smb-enum-shares -p 139,445 <target-ip>  
nmap --script vuln -p <ports> <target-ip>
```

- Script **categories**: `default`, `safe`, `vuln`.
- `ftp-anon` → "Anonymous FTP login allowed."
- `smb-enum-shares` → lists the shares.
- `--script vuln` → safe vuln-detection checks.

Compare NSE output to your **manual** findings — do they agree?

Automated vuln scanners (awareness)

Tool	Notes
Nessus Essentials	Free tier, registration-gated, IP-limited
OpenVAS / Greenbone	Free, fully open-source

- **Strength:** broad coverage, fast, thousands of checks.
- **Weakness:** noisy, **false positives**, no human context.

They flag *possible* vulnerabilities — a human still verifies.

Lab Part C + optional D

Part C — NSE scripts:

```
nmap --script ftp-anon -p 21 <target-ip>  
nmap --script smb-os-discovery,smb-enum-shares -p 139,445 <target-ip>
```

Record what each reported; compare to your manual findings.

Part D (optional) — automated scan: run Nessus/OpenVAS, **or** analyze the instructor's sample report. Record top findings + CVSS; mark suspected false positives.

Exit ticket — Day 3

Give **one strength and one weakness** of an automated vuln scanner vs manual enumeration.

Day 4

Mapping findings to CVEs, false positives, and building an attack plan

Warm-up

You found `vsftpd 2.3.4`. How would you find out if that version is **dangerous**?

Look it up. A specific version maps to specific, public **CVEs**.

Reading a CVE

- **CVE** = Common Vulnerabilities and Exposures — a public ID for one known flaw (e.g., `CVE-2011-2523`).
- **CVSS** = a **0-10 severity score** (higher = worse).
- A CVE entry tells you: what it is, affected versions, and how severe.

Map your **starred versions** from Unit 08 to their CVEs.

Example CVE mappings (Metasploitable 2)

Service & version	CVE	What it is
vsftpd 2.3.4	CVE-2011-2523	Backdoor command execution (CVSS ~10)
Samba 3.x	CVE-2007-2447	"username map script" RCE
UnrealIRCd 3.2.8.1	CVE-2010-2075	Backdoor

Map only. **Do NOT exploit** — that's Module 3.

False positives

- A **false positive** = a "vulnerability" a tool reports that **isn't real or exploitable**.
- Scanners over-report — they match patterns without context.
- **Verify manually** before trusting a finding: check the version, the config, the actual behavior.

A "critical" finding you can't reproduce is a lead, not a fact.

Building the attack plan (planning only)

Turn **verified** findings into a prioritized plan:

Service & version	Port	CVE(s)	CVSS	True positive?	Why it matters
vsftpd 2.3.4	21	CVE-2011-2523	~10	Yes	Backdoor → likely first target

Prioritize high-CVSS, **confirmed** findings. List "what I'd try first, and why." **No exploitation.**

Lab Part E — CVE mapping + attack plan

1. **Map** 2–3 starred versions to their CVE(s) and CVSS.
2. Fill in the CVE-mapping table; flag at least one likely **false positive** and propose manual verification.
3. **Draft a prioritized attack plan** — order what an attacker would try first and why.

Do not exploit anything. We stop at the plan.

Exit ticket — Day 4

What is a **false positive**, and how would you **verify** a scanner finding before trusting it?

Day 5

Recon mini-project (Module 2 milestone)

Warm-up & ethics re-anchor

We can build an attack plan — why do we **STOP** before exploiting?

- **Finding a vuln is not permission to exploit it.**
- Exploitation is a separate, more serious act needing its own authorization.
- In this course, exploitation waits for **Module 3** on authorized targets.

The Recon mini-project (Module 2 milestone)

The capstone of the whole module — a professional **Recon Report** combining:

- **Unit 07** — passive recon context/awareness
- **Unit 08** — active scanning results
- **Unit 09** — enumeration, vuln findings, CVE mappings, attack plan

This is a graded **Project** (25% category). Get the rubric **before** you start.

Recon report — structure

1. **Scope statement** confirming authorization (planning only, no exploitation)
2. **Methodology** — recon → scan → enumerate → vuln-map phases
3. **Findings** — each with evidence, version/CVE, and severity
4. **Recommended remediations** — specific, actionable fixes per finding

One professional document that tells the whole story.

Findings → remediations

Finding	Remediation
vsftpd 2.3.4 (backdoored)	Upgrade/replace FTP server
Anonymous FTP allowed	Disable anonymous login
Open SMB shares + users exposed	Restrict shares, require auth
Old OpenSSH version	Patch to a supported release

Every finding gets a fix. That's what makes it a **report**, not a brag.

Lab — assemble the mini-project

- Open your Unit 08 annotated scans and Parts A–E findings.
- Build the multi-section **Recon Report** on the **authorized lab target**.
- Include the scope statement; keep it **planning only**.

This report and attack plan become the launch point for **Module 3** (exploitation) and the final pentest report (Unit 17).

Ethics & Authorization

Enumeration and vuln scanning are ACTIVE — and louder than a port scan.

They send probes and sometimes **login attempts** to the target. **All of it requires authorization.**

Finding a vuln is NOT permission to exploit

- A scanner saying "*critical vulnerability*" is a **finding**, not a green light.
- Finding a weakness and attacking it are **completely different acts** — legally and ethically.
- Real, unauthorized finding? Follow **responsible disclosure** (Unit 01): don't post it, don't exploit it — report it to the owner.
- We stay on the **authorized lab target** and **stop at the plan**.

Discussion

You scan a friend's website **without asking** and a tool reports a critical vulnerability.

What are your **legal and ethical obligations**? What should you do — and what must you **absolutely NOT** do?

Recap

- **Scanning → enumeration → vuln scanning** — each digs deeper.
- Manual enumeration finds context (users, shares) tools miss.
- **NSE** scripts and automated scanners speed things up — but produce **false positives**.
- **CVE + CVSS** turn a version string into a measured risk.
- **Finding a vuln is not permission to exploit it.** We stop at the plan.
- Everything stays on the **authorized lab target**.

Key vocabulary — quick review

Term	Meaning
Enumeration	Digging into a service for users/shares/versions
Vuln scanning	Matching services to known weaknesses
SMB	Windows file/printer sharing (often enumerable)
NSE	Nmap Scripting Engine
CVE / CVSS	Public vuln ID / 0–10 severity score
False positive	A reported "vuln" that isn't real
Attack plan	Prioritized list of what to try, and why

Exit ticket — Day 5 + homework

Exit ticket: one sentence on responsible disclosure.

Homework:

- Finish the Recon mini-project report draft.
- ½-page: "A scanner flags a 'critical' vuln on a server you don't own. What do you do and what must you NOT do?" Use **authorization** and **responsible disclosure**.

Module 2 complete. Next: Module 3 — Exploitation, on authorized targets only.